



Office Security Plan & Network Segmentation

George Aslanidis

George Aslanidis

Table of Contents

<i>Project Description</i>	2
<i>Proposed Design</i>	4
Staff Description	4
Physical Design	6
Network Design	8
Conclusion.....	10
Business Case	10
<i>Implementation Details</i>	11
Implementation Overview	11
Physical Design Implementation	11
Network Design Implementation	12
Employee Training & Operations Testing Period	13
Physical & Network Design Implementation Gantt Chart	15
<i>Novel Technologies and Testing & Assurance Methods</i>	16
Adoption of Novel Technologies	16
Testing	17
Assurance Methods	17

Project Description

Onya is a modern creative agency that provides complete marketing and branding solutions to businesses seeking to start, grow, or strengthen their presence in the market. The company's services can cover a full brand-building office, where Onya's team will be responsible for creating graphic designs, logos, digital and physical campaigns, content strategies, social media marketing, website design, and website development.



Onya orchestrates all of its departments in a very creative and synchronised way so that the clients' businesses can get cohesive and coherent results for their brand across multiple domains, from social media marketing to web design, while at the same time keeping it professional as creativity is smoothly combined with technical and security expertise to protect the company's clients' data and sensitive information.

Overview of assets to be protected:

- Client marketing data (ex., analytics, reports)

- Credentials (ex., WordPress admin accounts, Github passwords, employee user credentials, social media account passwords, etc.)
- Internal operational files (ex., HR, finance, employee data)
- Onya's Database
- Employees' LAN network

As Onya works with numerous clients, a lot of sensitive client information needs to be handled with continuous protection and confidentiality. Some of the company's sensitive assets contain classified marketing data (ex. website analytics, etc.), website access credentials (ex. wordpress admin account passwords), client brand files containing original work (ex. brand logos, graphic designs, etc.), and sometimes even passwords for social media accounts, security needs to be part of the core of the business and office environment. Although most of the company's operations are conducted from inside the office, where shared systems and centralized storage are used, Onya allows remote collaboration for its employees as well.

Currently, as most of the companies worldwide, Onya makes use of some famous online tools. The office allows for the use of Google Workspace, Adobe Creative Cloud, and some project management platforms like Trello and Slack, as they are proven to boost productivity and time management. However, to improve security, the company has asked for new physical plans for the office area, as well as for their digital assets and workspaces through a complete security plan that will safeguard both the clients' data and the employees' work, while at the same time keeping the workflow smooth, fast, and uninterrupted.

Proposed Design

Staff Description

Onya is a small-sized company, founded by a former “Marketing Specialist”, has eight different roles within its ranks, and employs 12 people. The company’s roles and employees are:

1. Founder & Head of Marketing (1 Person):

Oversees the company’s strategy and all marketing activities, handles client relations, and approves final results before their delivery to the clients.

2. Lead Designer (1 Employee):

A graphic designer role with years of experience in the field that supervises design work done by the rest of the company’s graphic designers, makes sure that all designs produced (logos, etc.) are aligned with the marketing strategies by working closely with the marketing “Content Strategist”.

3. Senior Graphic Designers (2 Employees):

Create visual designs, logos, campaign assets, web designing, and in charge of guiding the junior designers’ work.

4. Junior Graphic Designers (2 Employees):

Assist the senior graphic designers with design production and edits following their instructions.

5. Content Strategist (1 Employee):

In charge of creating the brand identity of clients' businesses (logos, company storytelling, marketing campaigns, etc.), supervises the "Social Media Manager", and works closely with the "Lead Designer" to communicate the direction that the creative work should take.

6. Social Media Manager (1 Employee):

In charge of Onya's and clients' social media management, overseen by the "Content Strategist" and works closely with him/her to do online content creation and campaigns.

7. Web Developers/Designers (3 Employees):

Work closely with the "Lead Designer" to design the clients' website layout, style, interfaces and overall user experience (UI/UX), and in charge of developing and maintaining Onya's and clients' websites.

8. IT & Systems Administrator (2 Employees):

Responsible for managing and securing Onya's network, hardware, software, as well as digital assets, ensures the protection and integrity of all Onya's internal and client data, oversees backups and cybersecurity measures, and finally provides technical support to all departments to keep the company's operation as smooth as possible.

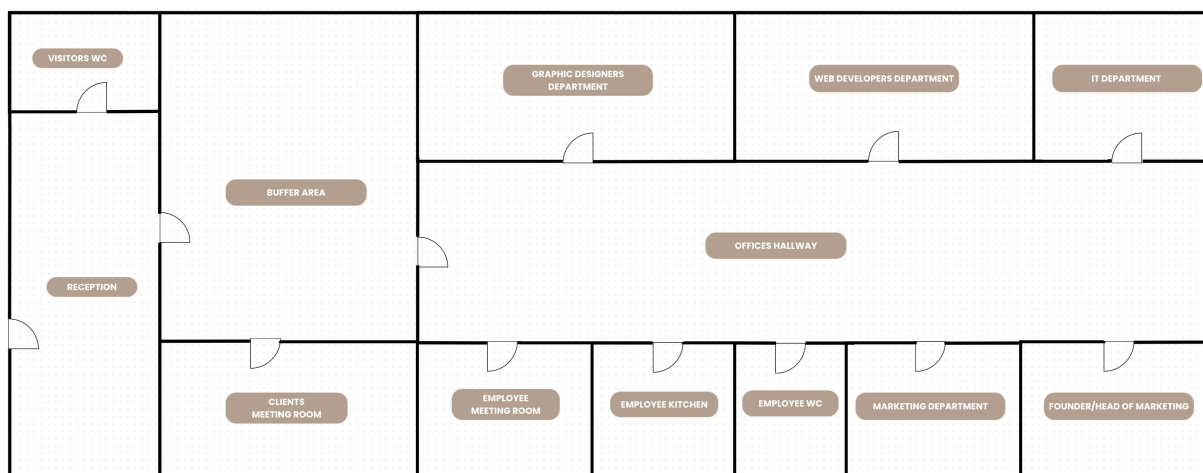
9. Receptionist (1 Employee):

The receptionist, as in every company, serves as the contact for clients and visitors, manages phone calls and emails, and finally schedules meetings between the company and clients.

Serves as the first point of contact for clients and visitors, manages phone calls and emails, schedules meetings, assists with administrative tasks, and supports all departments to ensure smooth daily office operations.

Physical Design

Physical Design of the Company's Office Building



For the physical security, Onya wants to include:

- CCTV monitoring for entry points, and the server room
- Alarm systems linked to emergency response services (security companies)
- Access control systems (keycard access), for office areas that need protection (server room)
- UPS Device to protect the network, data, and physical security device from power outages
- Buffer Area, to further restrict visitors access to restricted areas

Because Onya is a small to medium sized company, all office spaces can be accommodated on a single floor for optimized communication and collaboration between the departments, and also makes it easier to secure the building physically.

As seen on the schema above, the building is separated into two sections. The left section is dedicated to clients that are visiting the company's offices in

person. This section includes the reception, which serves as the first point of contact with the customers, a buffer area, one “Visitors WC”, and one “Clients Meeting Room”. In the reception area there will be a lounge where the clients can sit while waiting for their meeting, and once it’s time for them to enter the meeting room, the receptionist or an employee will be responsible to let the client inside the buffer area and/or the clients meeting room as the door leading to the buffer area can only be accessed with an employee keycard. The buffer area is an important zone as it gives clients access to meeting facilities as well as a WC while keeping the employee offices out of their reach.

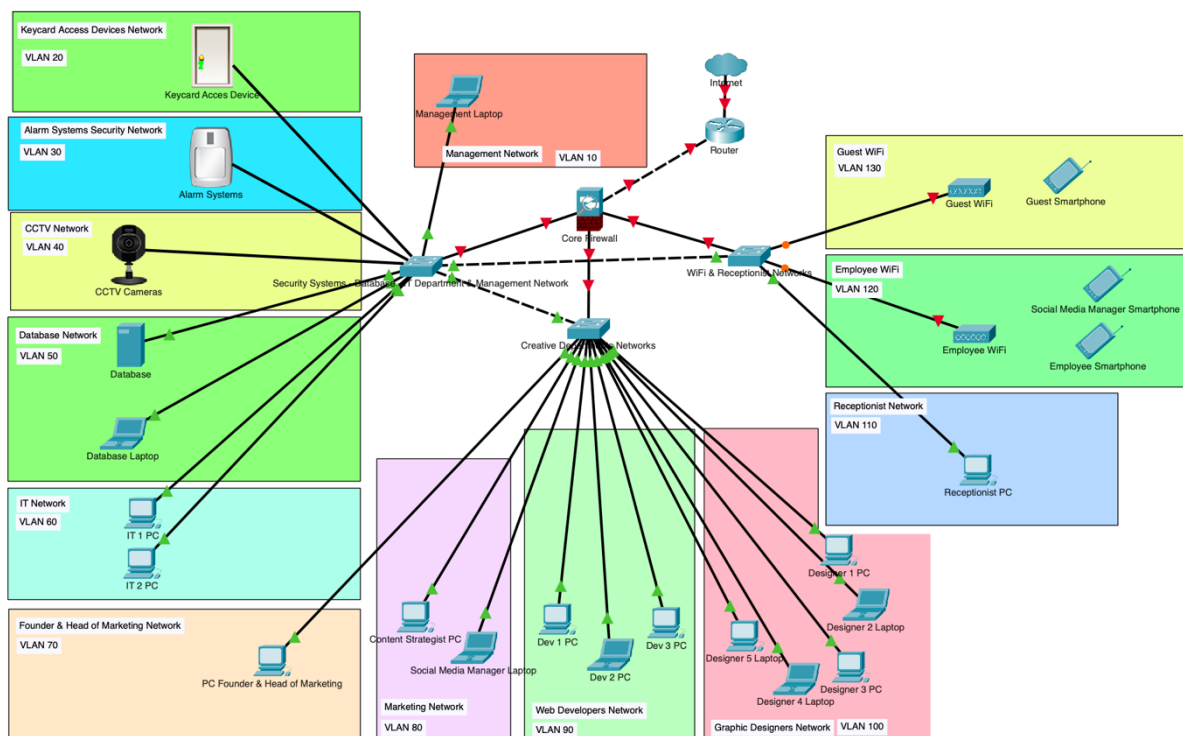
Moreover, the offices’ area hallway can only be accessed with an employee keycard, while the IT department and the founder’s office will be accessible only to the employees working in these offices with their own special keycards, as both spaces will contain sensitive information and operational systems. For example the IT offices will be the company’s systems admin workspace, and it will also contain a database filled with assets and information regarding previous customers, while the founder’s office (boss’s office) might need to contain Onya’s paperwork with sensitive information (payment details, customer information, etc.).

Furthermore, as far as more physical security is concerned, an alarm system and some CCTVs will be installed throughout the company’s building. At first, an alarm system with movement and door sensors will be installed throughout the whole building and office spaces to prevent any “unwanted visitors” when the company is closed. Because the company is a small one and cannot afford to pay for an in-house security team securing the building 24/7, the alarm system will be out-sourced to a security company that can provide such services, along with a person to attend Onya’s offices in times of need. Finally, four CCTVs will be installed throughout the building. One camera will point to the building’s entrance, one in the south wall of the reception area, one on the corner of the south and east wall of the buffer area, and a final one will be installed at the back (east wall) of the office hallway overlooking every room’s door in that area. The boss and the IT will be the only people with access to the cameras, while the footage recorded will be kept in the company’s database for 48 hours.

Finally, an Uninterruptible Power Supply unit (UPS) is going to be installed to boost Onya’s security. The UPS device will function as a backup power supply in cases of power outages so that the office’s systems are kept up and running. In the case where the UPS will be deployed, the router, the switches, and the office’s firewall will keep running, consequently, operations can continue normally if the outage happens during working hours, the CCTV, alarm system, and keycard access device will be also able to operate as intended, as well as the fact that data saved in the database or in the employees computers will not be affected by the outage.

Network Design

Network Design of the Company's Office Building



For digital security, the plans include:

- Firewall and secure segmented networks
- VLAN assignments for the secure network segmentation
- Encryption for stored and/or transmitted data
- Multi-factor authentication for all user accounts
- Automated backups for design and development assets
- Regular system updates and patch management
- Employee training on cybersecurity awareness

As seen in the diagram above, Onya's network was segmented into multiple networks connected in a star topology. The star topology offers many advantages, especially to a small company as Onya, such as easy scalability

without complex routing in case there is a need for expansion or general changes in the network, it simplifies security and monitoring which is very important as the company cannot employ more than two people to cover this position, it is easy to isolate networks for the cameras, IT and database, improving security, and finally, file sharing and communication between the departments can be easily managed.

As mentioned, the company's network has been segmented into multiple smaller ones, increasing security and making it easier to isolate threats. First of all, a firewall must be installed between the router and the three company switches to act as the first line of defense against attackers trying to reach Onya's LAN, and the last to allow packets to exit the office's network.

Then, the network must be segmented properly by assigning dedicated VLANs to each department throughout the network. As seen and labeled in the network image above, the networks are separated into VLANs as:

- VLAN 10: Management Network
- VLAN 20: Keycard Access Devices Network
- VLAN 30: Alarm System Network
- VLAN 40: CCTV Network
- VLAN 50: Database Network
- VLAN 60: IT Department Network
- VLAN 70: Founder & Head of Marketing Network
- VLAN 80: Marketing Department Network
- VLAN 90: Web Developers Department Network
- VLAN 100: Graphic Designers Department Network
- VLAN 110: Receptionist Network
- VLAN 120: Employee WiFi Network
- VLAN 130: Guests WiFi Network

These VLAN separations will allow for precise control over the inner network communications, ensuring that each department can only reach the networks that are permitted by the security policy.

Furthermore, even though every network is protected by the core firewall and VLAN segmentations, there must be a clear separation between the networks that guests and employees use, so a "Guest Wi-Fi" has to be installed to keep customers away from the inner company's network, and for the employees' Wi-Fi needs there will be a separate one that each employee will have to log in with his/her credentials because each employee will be allowed different functionalities. For example, uploading/downloading assets or files online will not be allowed through the Wi-Fi, with some exceptions for specific online services that the company might use (ex. Google Workspace), however, it

is vital for the marketing team to use social media for online campaigns, thus they must be able to use them through the employees Wi-Fi.

Moreover, there will be a “Management Network” which will be handled by the IT employees. This network has admin clearance and will handle the CCTV, the Alarm System, and the Keycard Devices Network, and will be used to detect and mitigate attackers either attempting to access the company’s network either through the internet and isolate compromised inner networks.

Finally, all other networks will be restricted from accessing a different department’s assets (of course unless shared between them), with the only exceptions being the “Founder & Head of Marketing Department” network as the boss of the company needs to have access to the CCTVs, as well as the Management end devices that need to have logical access to every department, but not the other way around (other networks cannot access the Management Network).

Conclusion

Combining these physical security measures with the robust digital “Security Best Practices”, the company’s files and accounts, web projects, and client information will be safe and away from malicious users, and the company will be able to achieve its ultimate goal of keeping the workflow up while keeping it secure and professional to build client trust and produce long-term relations with them.

Business Case

Even though Onya’s budget was restricted, the designs that are cited above will cover its needs for physical and network security. From the physical design perspective, the combination of CCTV, alarm system, buffer area, and keycard accessible doors ensure that all assets are protected from potential intruders getting hands-on access to the company’s sensitive areas containing important assets. On the other side, the network segmentation allows employees to work, save, use, and share any file/asset they need, as the network’s firewall will automatically block any suspicious activity and block it (ex., file sharing outside of the LAN, suspicious software trying to access restricted departments’ LANs, etc.). This means that client payments will be safe in the “Founder’s” network, web developers’ WordPress credentials will not be compromised, and Onya’s database will be well protected behind its firewall and on-site access only. Of course, all these physical and network measures must be accompanied

by employee care, and that is why the employees need to be properly informed on how to use the company's network effectively.

Implementation Details

Implementation Overview

After the finalisation of the proposed physical and network designs, our company intends to implement and test Onya's new infrastructure within 9 months. To ensure our client that our security company will deliver pristine and error-free results, the installation and testing of the infrastructure will be split into three phases:

1. Physical Security Implementation:
 - a. Acquisition of Physical Infrastructure Materials and Devices & Networking Devices
 - b. Building of Physical Infrastructures
 - c. Installation of Physical Security Devices - Core & Management Networking Devices
 - d. Management Network Implementation
 - e. Test & Verify for Physical Security
2. Network Security Implementation:
 - a. Installation & Configuration of all other Network Devices
 - b. Test & Verify for Network Security
 - c. Finalisation of As-built Documentation
3. Employee Training & Testing Period:
 - a. Employee Training on both Physical and Network Security
 - b. Operations will begin normally as a testing period

Physical Design Implementation

In the first 4 months, the goal is to have the physical infrastructure and security ready and tested, so that our company can proceed with the network designs without distractions.

During the 1st month, we will start acquiring all the necessary equipment for both the physical and the network designs, and we plan on starting the construction of the building's new layout as soon as possible during the first 2 weeks of this month. By the end of the 2nd month, all construction regarding the building's layout should be finished, as we need month 3 to be dedicated to the installation of all equipment regarding the physical security. Finally, the 4th month will be dedicated to testing and verifying that all the necessary physical security equipment and operations are up and running as expected.

The timeline for the physical design implementation will be as follows:

Month 1-2 – Items Acquisition & Layout Construction:

- Acquisition of Networking Devices, CCTV cameras, Alarm System, Keycard Access Control Hardware, Construction Materials needed for the Offices New Layout, UPS Device.
- New office building layout construction.
- As-built documentation throughout the implementation

Month 3 – Physical Security Installations:

- Installation of CCTV in the entrance, reception, buffer area, and the office hallway.
- Installation of the Keycard System for the Office's Doors.
- Installation of the Alarm System with Motion Sensors in every Office Room.
- Installation of the Company's Core Router and Firewall, the Security Devices' & Management's Network Switch (PC).
- Installation of the UPS Device.
- Networking Configurations to connect the Alarm Security Network with the Internet (to the third-party security company) and the Management Network, CCTV Network with Management Network.
- As-built documentation throughout the implementation

Month 4 – Testing & Verification:

- Alarm system motion sensors testing to make sure they sound the alarm properly when motion is detected and the third-party security company is getting the notifications.
- Testing the keycard access permissions based on employees' and visitors' IDs.
- Confirming that CCTV footage is saved in a backup for 48 hours before deletion in accordance with the company's policy.
- Power outages simulations to make sure the UPS system works as intended.
- Final fixes for the physical infrastructure.
- As-built documentation throughout the implementation.

Network Design Implementation

The implementation of the network design is going to start at the 5th month and span for two total months. On the 5th month, our company wants to have every employee's computer, office servers, and networking device installed to start assigning the VLANs to the departments, configuring the Firewall's networking and access rules, have all employee accounts created with assigned roles based on the Least Privilege policy, and ensure that automations are in place to protect the company's data. Moreover, on the 6th month, as the network should already have been installed, we plan on running multiple tests to verify that our network was set-up as expected and has no vulnerabilities.

The timeline for the network design implementation will be as follows:

Month 5 – Implementation:

- Installation of all the office computers.
- Firewall configurations to setup for the rest of the network VLANs isolation and access rules.
- Employee Accounts and Credentials creation with access implementation based on the Least Privilege policy.
- Multi-factor authentication system implementation for the employee accounts.
- Database and backup systems set up.
- Automation for backups for the designs, development documents, and client data for contingency planning.
- As-built documentation throughout the implementation.

Month 6 – Testing & Verification

- Penetration testing to find any vulnerabilities in the network and the employee accounts.
- Firewall testing to ensure the rules and isolation policies were implemented as intended.
- Backup tests to make sure that the process is working properly for data integrity.
- Simulation of power outages to make sure that the UPS system and backup automations are working as expected.
- Simulation of network failures to make sure that the disaster recovery system works properly.
- Final fixes in the network infrastructure setup that might occur.
- As-built documentation throughout the implementation.

Employee Training & Operations Testing Period

During the first 2 weeks of the 7th month, our security company will run a training period for Onya's employees. Our company will make sure that the employees are familiar with the new physical and network infrastructure, security policies, and best practices for maintaining a safe work environment. Lastly, during the last 2 weeks of the 7th and the first 2 weeks of the 8th month, we plan on having a testing period. Onya's new offices will open up for the first time, employees will come to work, clients will be able to visit the offices, while our security company will be monitoring the building's and the network's operations regularly throughout the month by having our security experts on-site at least 2-3 times per week. In the case that something goes wrong either with the physical or network security our company has the last 2 weeks of the 8th month and the whole of the 9th month reserved for emergency adjustments.

Month 7 – 2 Weeks – Employee Training for both Physical and Network Infrastructures:

- Show employees how to use their keycard access cards and which areas they can access.
- Brief the staff on the company's security rules and policies.
- Train the employees on how to recognise phishing emails, create safe passwords, share files securely within the network, and how to use the multi-factor authentication system.
- Help employees understand their access level and what they can access within the company's network.
- Give employees a final hands on session on how to use the network safely (ex., never use the Guests' WiFi, never use the company's network to access unreliable webpages, etc.).

Month 7 (Last 2 Weeks) - 8 (First 2 Weeks) – Office Operations Start as Testing Period

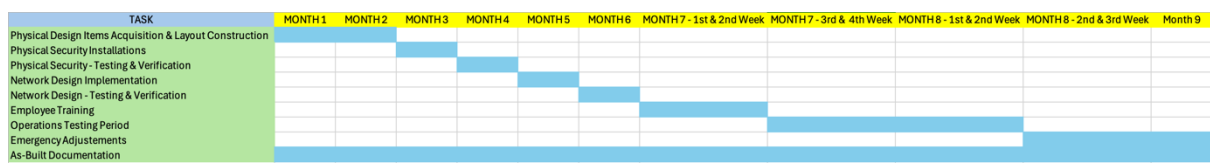
- Physical Security Checks:
 - Keycard Access Devices
 - CCTV
 - Alarm Systems
 - UPS System
- Network Security Checks:
 - VLANs & Firewall Access Rules & Operations Monitoring
 - Employee Account Monitoring for Irregular Traffic or Access
 - Data are stored and backed-up as expected
 - Network Monitoring for Unusual Traffic
- Employee Checks:
 - Ensure that they do not have any trouble with the new keycard access doors
 - Verify that they use only Onya's equipment and devices for work and not their personal devices
 - Make sure that they understand and follow Onya's new policies
- As-built documentation throughout the implementation.

Month 8 (Last 2 Weeks) - 9 – Emergency Extension Period & As-built Documentation Finalisation

- Reserved as an "Emergency Extension Period" in the case that there are further fixes and/or implementations that need to be done, either for the Physical Design, the Network Design, or even both.
- Creation of a polished and final as-built documentation that will include:
 - Network Physical & Logical Topology Maps.

- Configuration Set-up Summaries for each Network and Endpoint Device with the Settings, IP Assignments, and Hardware Configurations.
- Firewall and VLAN Documentation with the details for the Network's Segmentation, Security and Traffic Control Rules.
- An Access Control Map showcasing the Access Level and Permissions of each Employee Role.

Physical & Network Design Implementation Gantt Chart



Novel Technologies and Testing & Assurance Methods

Adoption of Novel Technologies

Several modern technologies will be introduced throughout the implementation period in order to support Onya's physical and network security needs. These technologies were chosen based on the size of the company, the workflow, and the sensitivity of the data that are handled by each department.

A Fortinet FortiGate FG-60F firewall will be deployed as the company's core firewall to provide packet inspections, threat protection, as well as strict VLAN segmentation between the departments. This kind of firewall can support a secure VPN access in case that the company will later need to hire or allow employees to work remotely and ensure that remote work will not affect the company's security.

As for the physical protection, the office will use electronic keycard access devices to control entry to the company's spaces and offices, and ensure that only authorised personnel can access the offices. This will keep visiting clients away from the employees' offices and common spaces, and employees can only access their dedicated offices. For instance, sensitive areas such as the server room and the management area that are going to be hosted in the IT Department's quarters, will be accessible to only the IT and Management personnel and no other employee (except if they are granted access). Moreover, CCTV cameras will be providing continuous monitoring of the whole building workspaces, and the alarm system that is going to be connected to a third-party security company will offer 24/7 security in the case of a forced entry attempt after working hours. The proposed camera type would be the Hanwha Wisenet XNV-A6083R 4K AI Dome Camera, as it can provide state-of-the-art capabilities such as 4K resolution video, and AI analytics capable of recognising people and vehicles effectively which can be proven to be very helpful for monitoring the entrance of the building as well as sensitive areas such as the door of the server room.

Furthermore, to safeguard operations in the case of an unexpected power outage, a UPS device will be added to the company's equipment. The recommended device for this task would be the APC Smart-UPS SRT 3000VA, as it is a state-of-the-art UPS device and will make sure that significant systems, such as the CCTV, alarm systems, keycard system, as well as all the networking devices, will be kept operational until the power will be restored.

All these technologies will be implemented and deployed according to the project's timeline. When the physical infrastructure is ready and tested, network segmentation will begin, the firewall rules will be configured, and the network security systems will be tested to confirm that everything was implemented as intended.

Testing

During the operational period during the last two weeks of month 7 and the first two weeks of month 8, multiple physical and network systems/security tests will take place. This period is meant to confirm that the new systems function as intended while the employees and clients interact with the office's infrastructure.

Testing will include:

- Physical System Checks: Verifying that the keycard system operates correctly based on the intended permissions, confirming that the area covered by the CCTV is good and that the recording quality is pristine, making sure that alarm systems operate normally, and testing that the UPS system will work successfully by periodically doing controlled power interruptions.
- Network System Checks: Confirming the VLAN separations between departments, making sure that firewall rules are enforced, inspecting the backup automation systems, and validating the security of the employee accounts.

By doing these tests while the company is actively operating, issues that might come up can be identified and corrected before the end of the project's timeline.

Assurance Methods

After the deployment, Onya will use several assurance methods to keep its environment secure and reliable in the long run. These checks will help ensure that any misconfigurations, outdated systems, and small network or physical faults will not accumulate over time.

The following assurance methods will be conducted regularly:

- Monthly vulnerability scans: To detect weak points, outdated software, or misconfigured devices
- Firewall and Segmentation reviews: To verify that the access rules remain accurate as the company grows and changes.
- Monthly Backup Restore Tests: To make sure that the clients' designs, development files, and different operational data can be recovered without any issues.
- Weekly CCTV and Alarm System Checks: To confirm the cameras, footage storage, and alarm systems operate successfully.
- UPS tests every 6 months: To verify that the UPS system is still operational and that the backup automation systems are working as expected.
- Yearly Employee Training: Short sessions to remind the staff of safe password creations and the proper use of the company's network, and to make them aware of new phishing techniques.

These assurance methods should help the company to keep its infrastructure and operations stable and secure throughout the years, and reduce the risks of data loss, unauthorised access, and any unexpected issue.